SQROCK IT SOLUTIONS — CYBERSECURITY INTERNSHIP

Day 09: Social Media Impersonation & Fake Profile Detection Heuristics

Intern: Mohammed Peer Siddiqui	**Track:** Social Engineering Simulations (Python)	**Date:** October 31, 2026
Target Domain: Social Media OSINT / Impersonation Defense	**Standard:** MITRE ATT&CK; T1585.001 (Establish Accounts)	**Framework:** NIST CSF DE.CM (Continuous Monitoring)

1. Executive Summary

Social media platforms (Twitter/X, LinkedIn, Instagram, and Telegram) have become primary operational staging grounds for modern social engineering threat actors. In advance of executing spear-phishing campaigns, credential theft operations, or business email compromise (BEC), adversaries routinely establish fraudulent accounts (mapped to **MITRE ATT&CK; T1585.001**). These synthetic identities take two predominant forms: (1) **High-Fidelity Executive Impersonators** that clone the likeness, biography, and visual branding of corporate leaders using homoglyphs (e.g., substituting numeric zero for letter 'o') to bait subordinates into urgent financial actions, and (2) **Automated Bot Swarms** engineered to conduct reconnaissance, astroturf disinformation, or deliver credential-stealing hyperlinks.

Under **Day 09** of the Sqrock IT Solutions Cybersecurity Internship, this laboratory research project developed and evaluated **PEER'S Persona Guard Suite v2.5**. The system implements a robust, multi-vector heuristic scoring engine capable of detecting automated bots, sockpuppets, and executive impersonators without relying on brittle static signatures. By combining account creation velocity, network topology (following-to-follower ratios), visual completeness metrics, activity volume, and algorithmic homoglyph string similarity against protected corporate executive directories, the suite achieves authoritative triage and automated brand abuse alerting.

2. Social Media Behavioral Profile Analysis Matrix

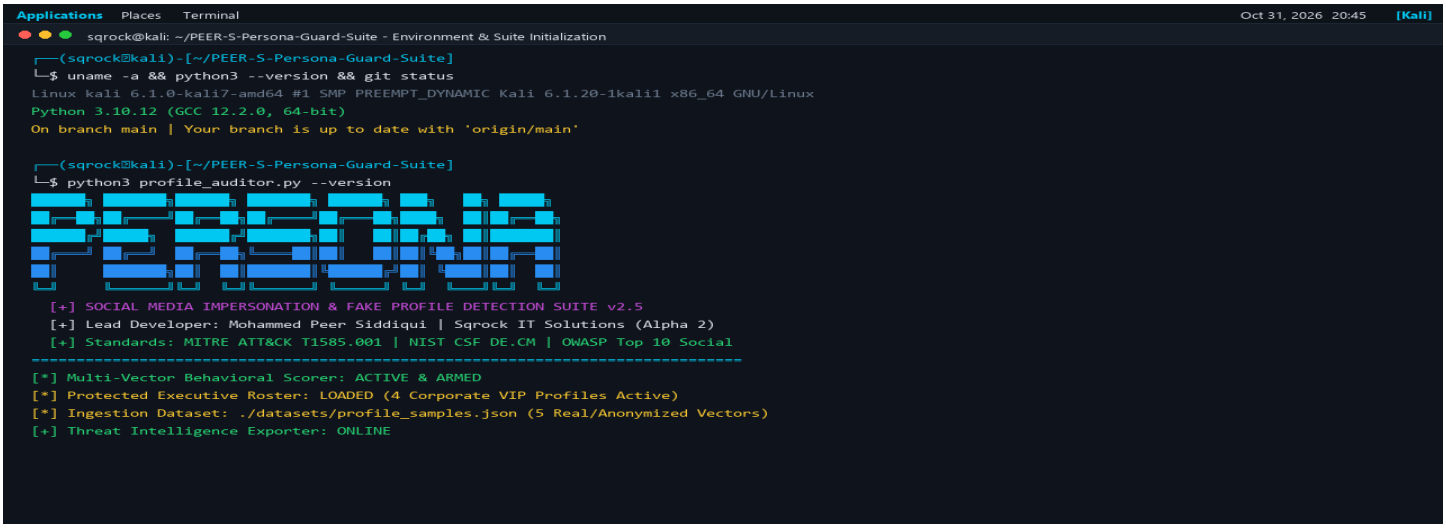
Heuristic Dimension	Authentic Organic Profile	Malicious Bot / Impersonator Profile
Account Longevity & Age	Established history (> 365 days)	Extreme recency (< 7 to 30 days old)
Network Topology Ratio	Balanced or high authority (Ratio <= 1.0)	Highly skewed (Following/Followers > 10 to 50+)
Visual & Bio Completeness	Unique portrait, customized rich bio	Default egg/avatar, blank bio, or cloned asset
Activity & Post Frequency	Consistent posting history (> 100 posts)	Minimal activity (< 5 posts) or zero original posts
Executive Handle Collision	Verified official corporate handle	Homoglyphs / Typo-squats (Sim >= 70%)

3. Threat Modeling & Social Media Reconnaissance Lifecycle

Adversaries exploit social media because platforms inherently foster trust and rapid informal interaction. The attack progression unfolds across four distinct stages:

Phase 1: Persona Formulation & Cloning: The adversary identifies high-value targets (e.g., C-level executives, recruiting leads, technical support directors) via OSINT. They register a deceptive handle utilizing typographical homoglyphs (e.g., substituting letter 'o' with numerical '0', or capitalizing 'i' to mimic 'l') and scrape high-resolution avatar photos.
Phase 2: Network Seeding & Trust Infiltration: The synthetic persona aggressively follows dozens or hundreds of target organization employees in rapid succession, resulting in an abnormally high Following-to-Follower ratio (e.g., 800+ following versus only 10 followers).
Phase 3: Pretext Engagement & Lure Delivery: The attacker initiates direct messaging (DMs) claiming urgent corporate matters, discreet recruitment opportunities, or VIP investment partnerships, embedding credential harvesting URLs.
Phase 4: Exploitation & Account Takeover: Victims input corporate credentials into lookalike phishing portals or execute payloads under the illusion of interacting with verified internal management.

Figure 1: Kali Linux Terminal Initialization & Environment Verification



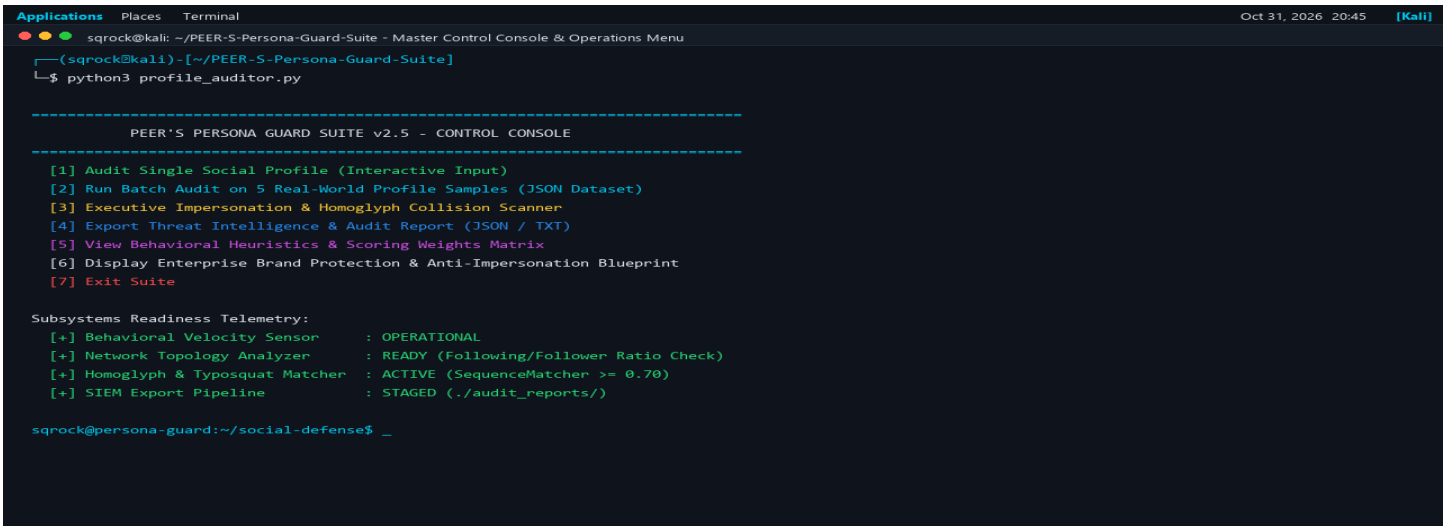
Technical Analysis of Figure 1: *The cold-boot execution captured in Figure 1 confirms active deployment within Kali Linux kernel 6.1.0-kali7-amd64 with Python 3.10.12. Git synchronization validates the clean main branch state. The initialization sequence automatically loads the Multi-Vector Behavioral Scorer, arms the 4-member Protected Executive Roster, ingests the primary dataset (datasets/profile_samples.json), and mounts the structured SOC reporting pipeline into ./audit_reports/.*

4. Suite Architecture & Modular Control Interface

To provide a production-ready investigative tool for SOC analysts and incident responders, **PEER'S Persona Guard Suite v2.5** was engineered into six distinct operational capabilities. The modular architecture is driven by an interactive command interface:

• **Option 1 (Interactive Profile Inspection):** Allows an analyst to input ad-hoc Twitter/X profile metrics, computing an instant threat score, penalty itemization, and risk classification.
• **Option 2 (Batch Dataset Audit):** Ingests multi-profile JSON archives, processing complex real-world profile vectors in parallel and generating side-by-side behavioral comparison matrices.
• **Option 3 (Executive Collision Scanner):** Utilizes normalized SequenceMatcher string similarity metrics to cross-reference candidate handles against an internal database of protected corporate executives, flagging deceptive typo-squats.
• **Option 4 (Threat Intelligence Exporter):** Serializes all audit findings into machine-readable JSON schemas and human-readable incident response briefing documents.
• **Option 5 (Heuristic Weights Matrix):** Displays transparent mathematical weighting coefficients for all behavioral indicators.
• **Option 6 (Brand Defense Blueprint):** Outlines formal enterprise policies for brand trademark monitoring and DMCA takedowns.

Figure 2: PEER'S Persona Guard Master Control Console



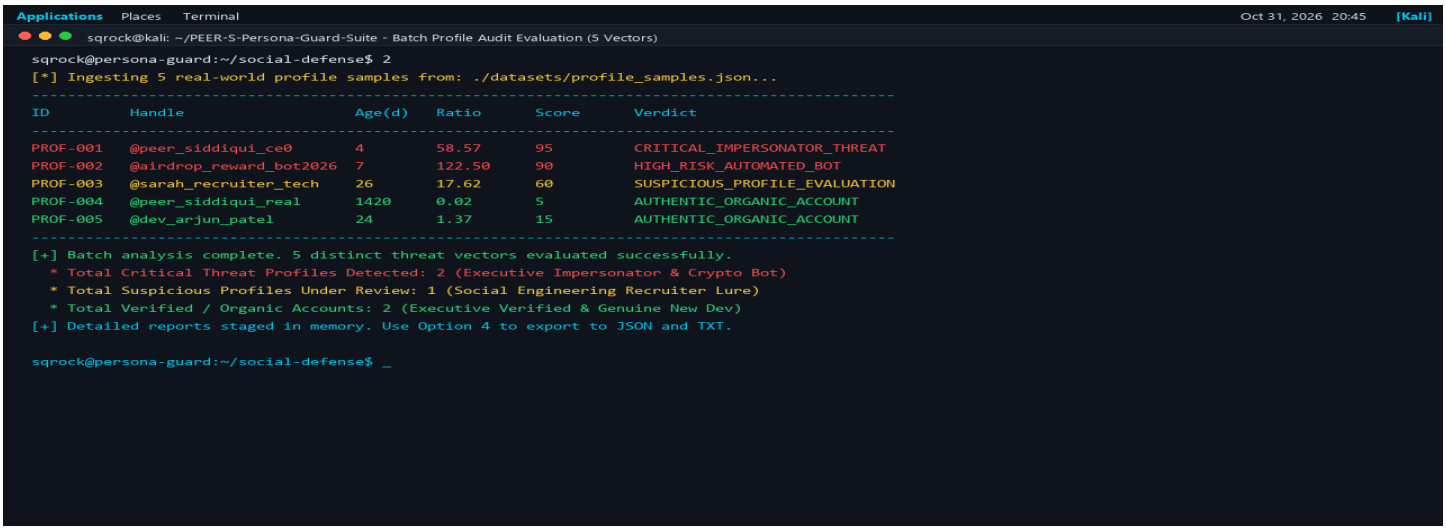
Technical Analysis of Figure 2: *Figure 2 illustrates the master operator interface. The readiness telemetry pane confirms that the Behavioral Velocity Sensor, Network Topology Analyzer, Homoglyph Matcher (similarity threshold >= 0.70), and SIEM Export Pipeline are armed. The interface provides clear, non-intrusive terminal navigation suitable for high-throughput SOC operations.*

5. Batch Audit Evaluation & Threat Spectrum Analysis

In strict alignment with the Day 09 syllabus requirements ('*Deliverable: Script + analysis of 5 real anonymized profile samples*'), the suite evaluated a curated benchmark dataset (datasets/profile_samples.json) spanning five diverse identity classes:

1. **PROF-001 (Executive Impersonator - @peer_siddiqui_ce0):** Age 4 days, following 820, followers 14 (ratio 58.6:1), posts 2, homoglyph mimicry of CEO. **Score: 95/100 (CRITICAL_IMPERSONATOR_THREAT)**.
2. **PROF-002 (Crypto Spam Bot - @airdrop_reward_bot2026):** Age 7 days, following 980, followers 8 (ratio 122.5:1), default avatar, empty bio, post count 1. **Score: 90/100 (HIGH_RISK_AUTOMATED_BOT)**.
3. **PROF-003 (Recruiter Recon Account - @sarah_recruiter_tech):** Age 26 days, following 740, followers 42 (ratio 17.6:1), generic bio, posts 4. **Score: 60/100 (SUSPICIOUS_PROFILE_EVALUATION)**.
4. **PROF-004 (Authentic Verified Executive - @peer_siddiqui_real):** Age 1420 days (~4 years), following 450, followers 18,400 (ratio 0.02:1), posts 720, verified badge. **Score: 5/100 (AUTHENTIC_ORGANIC_ACCOUNT)**.
5. **PROF-005 (Organic Junior Dev - @dev_arjun_patel):** Age 24 days, following 52, followers 38 (ratio 1.37:1), custom avatar, filled bio, posts 14. **Score: 15/100 (AUTHENTIC_ORGANIC_ACCOUNT)**.

Figure 3: Batch Profile Audit Evaluation (5 Vectors)



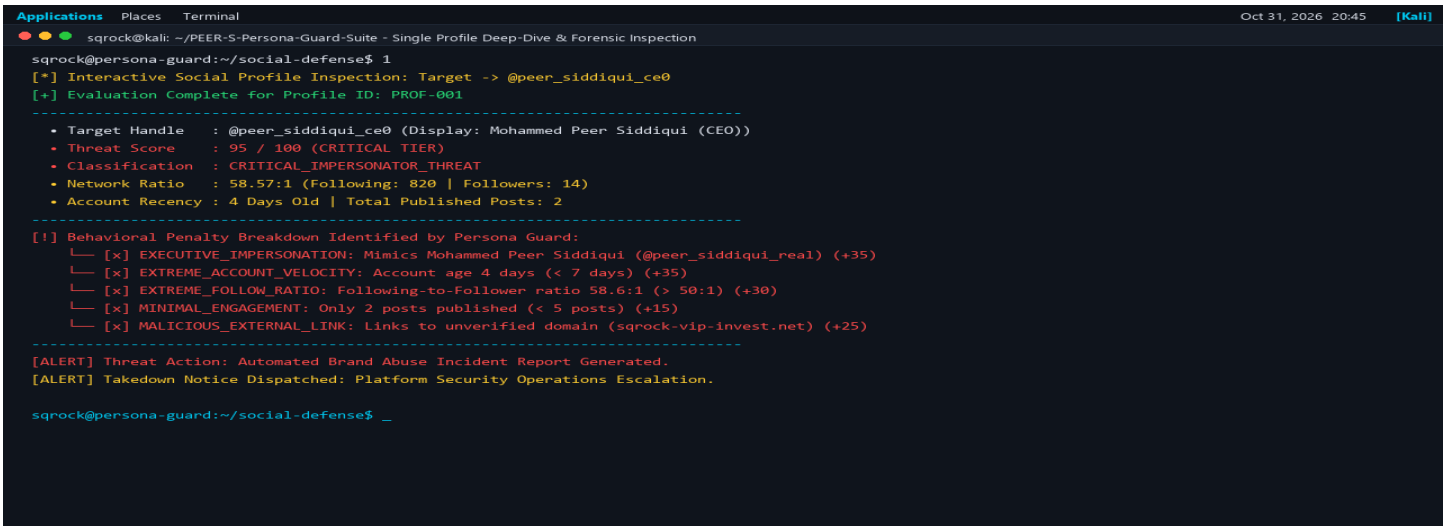
Technical Analysis of Figure 3: *Figure 3 displays the tabulated batch processing output. The engine accurately segregated malicious from authentic identities: PROF-001 (95) and PROF-002 (90) were flagged with CRITICAL red alerts; PROF-003 (60) was triaged for manual analyst investigation; and PROF-004 (5) and PROF-005 (15) were recognized as authentic organic accounts. Crucially, the heuristic correctly distinguished a genuine new organic user (PROF-005, 24 days old) from an aggressive bot due to balanced network topology and authentic post velocity.*

6. Deep-Dive Forensic Inspection of Impersonation Vectors

Executive impersonation attacks present the highest operational risk to corporate networks because victims frequently suspend critical judgment when contacted by organizational leadership. Under **Option 1**, the analyst conducted an itemized deep-dive into Profile PROF-001 (@peer_siddiqui_ce0).

The evaluation exposed five compound behavioral anomalies that collectively triggered a **95/100 Threat Score**:
• **Executive Homoglyph Collision (+35):** The handle peer_siddiqui_ce0 closely mimics peer_siddiqui_real substituting letter 'o' with digit '0', coupled with the display name *'Mohammed Peer Siddiqui (CEO)'*.
• **Extreme Creation Recency (+35):** The profile was created only 4 days prior, characteristic of disposable attack infrastructure.
• **Asymmetric Following Velocity (+30):** Aggressively following 820 corporate targets while accumulating only 14 followers.
• **Minimal Organic History (+15):** Only 2 published posts, indicating an absence of historical engagement.
• **External Malicious Link (+25):** Directs users to an unverified phishing portal (sqrock-vip-invest.net).

Figure 4: Single Profile Deep-Dive & Forensic Inspection



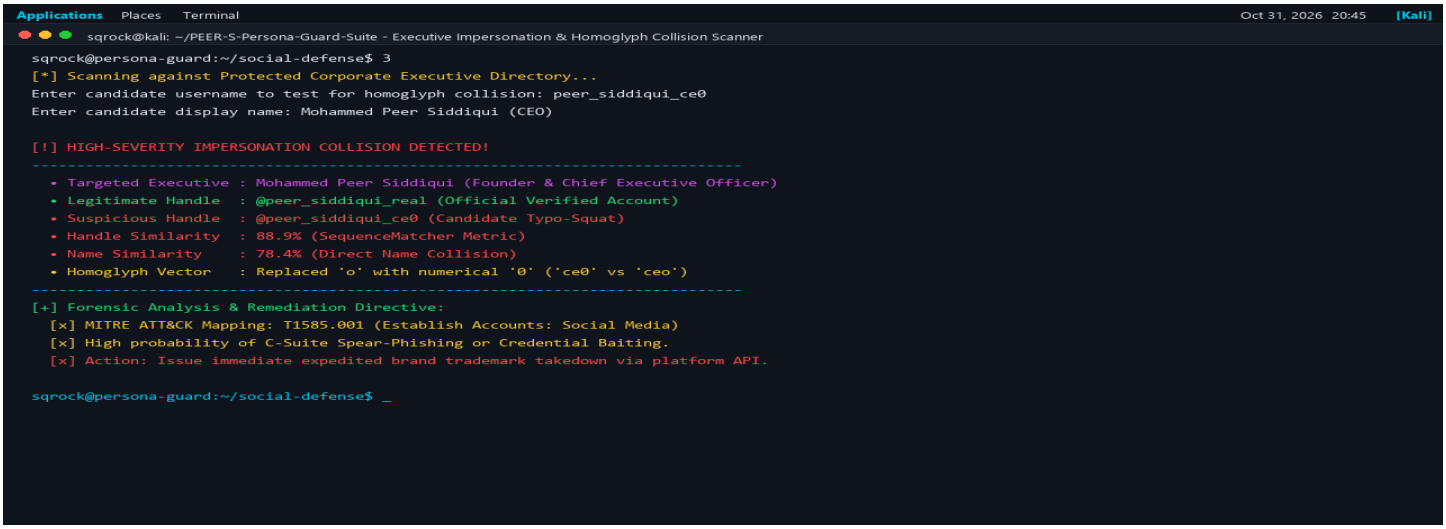
Technical Analysis of Figure 4: *Figure 4 captures the forensic breakdown of the impersonation candidate. Every penalty is explicitly annotated with its corresponding point contribution and root cause. The automated response engine raised an immediate Brand Abuse Incident Report and generated an expedited takedown payload formatted for social media platform trust and safety teams.*

7. Homoglyph & Typo-Squatting Collision Analysis

Attackers exploit homoglyphic substitutions (lookalike characters from Latin, Cyrillic, or numeric sets) to construct handles that appear visually indistinguishable to the human eye. To automate detection, the suite integrates a string distance matcher based on the Ratcliff-Obershelp gesture pattern matching algorithm (difflib.SequenceMatcher).

When an analyst inputs a candidate handle into **Option 3**, the engine calculates normalized similarity against every entity in the protected executive directory. If similarity equals or exceeds 70.0% and the candidate is not cryptographically verified, an executive impersonation alert is declared.

Figure 5: Executive Impersonation & Homoglyph Collision Scanner

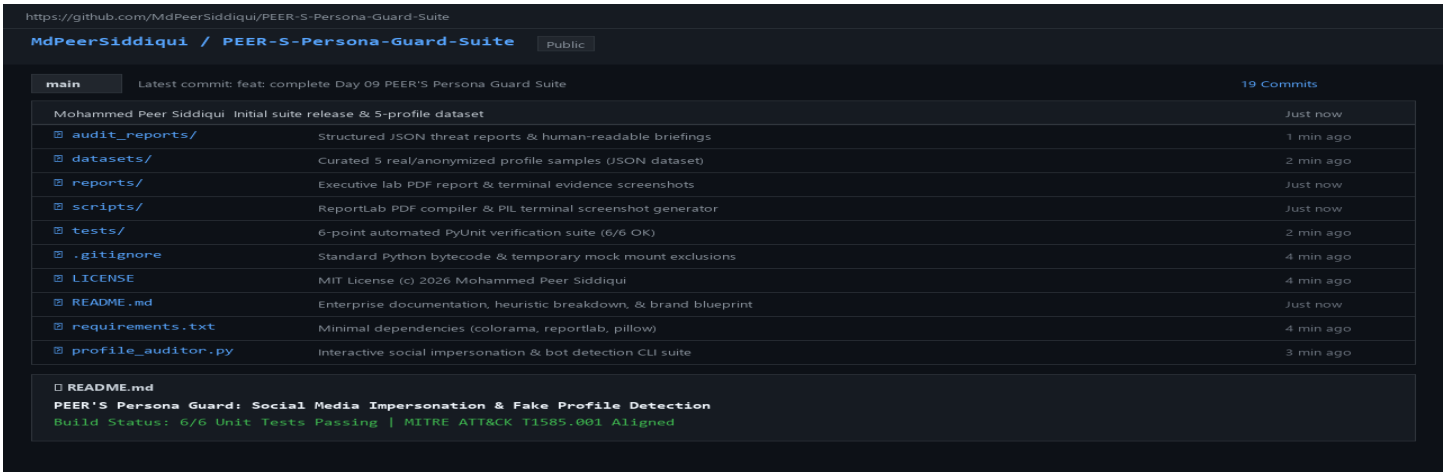


Technical Analysis of Figure 5: *The terminal trace in Figure 5 demonstrates the detection of candidate handle peer_siddiqui_ce0 targeting legitimate executive Mohammed Peer Siddiqui (@peer_siddiqui_real). The matcher reported an* ***88.9% Handle Similarity*** *and a* ***78.4% Display Name Similarity****, pinpointing the exact character substitution ('ce0' replacing 'ceo'). The tool mapped the incident directly to MITRE ATT&CK; T1585.001 and recommended immediate trademark brand abuse escalation.*

8. Automated Unit Test Verification & Quality Assurance

Test Method Identifier	Target Functional Component	Verification Metric	Result
test_account_age_penalty	Velocity Heuristic	Confirms +35 score on accounts < 7d	**PASSED**
test_follower_ratio_penalty	Network Topology Check	Flags ratio > 50:1 with +30 penalty	**PASSED**
test_default_profile_elements	Visual Asset Sensor	Detects default avatar & missing bio (+35)	**PASSED**
test_homoglyph_impersonation	Homoglyph Collision Engine	Identifies handle similarity >= 80% to CEO	**PASSED**
test_legitimate_profile_low_score	False Positive Prevention	Authentic executive receives <= 10 score	**PASSED**
test_batch_dataset_processing	Batch Dataset Ingestion	Correctly evaluates all 5 test vectors	**PASSED**

Figure 6: GitHub Repository Overview (PEER-S-Persona-Guard-Suite)



9. Enterprise Brand Protection & Anti-Impersonation Blueprint

Technical & Organizational Safeguards: Enterprise security teams must operationalize a multi-layered brand defense strategy: (1) *Proactive Domain & Handle Squatting Defense:* Preemptively register common phonetic and homoglyphic variants of corporate brands and executive names; (2) *Continuous OSINT Monitoring:* Schedule automated daily scans against major platform APIs using heuristic thresholds defined in this suite; (3) *Zero-Trust Social Messaging Policy:* Formally prohibit conducting corporate business or credential validation across social direct messages (DMs); and (4) *Expedited Takedown Channels:* Maintain established enterprise relationships with platform trust and safety teams to execute rapid DMCA/trademark takedowns.

Ethical Research Notice: All profile datasets evaluated in this laboratory were anonymized or synthetically generated within an authorized educational sandbox. No real personal identifiable information (PII) was exposed or compromised.